MODULE 32 · DOMAIN 5 - NETWORKING AND CONTENT DELIVERY

CloudFront and the Edge

Cache behaviours, OAC, VPC origins, edge functions, WAF, Shield and Global Accelerator.

DOMAIN 5 of 5 EXAM WEIGHT 18% MODULE 32 of 35

admin@sthithapragna.com

The edge does three things: **cache** so the origin is not asked, **filter** so bad requests never arrive, and **shorten the path** so traffic joins the AWS network sooner.

Distributions, origins and behaviours

- A **distribution** has one or more **origins** and a set of **cache behaviours** that decide which origin serves which path.
- Behaviours are matched by **path pattern in order**, and the **default behaviour, matching everything, is evaluated last**.
- That is how one distribution serves static files from S3 and **/api** from a load balancer, under one domain name.
- Each behaviour has its own **cache policy, allowed methods, TTLs and function associations**. They are not shared.

> ON THE EXAM
>
> Behaviour ordering is the same first-match logic as ALB listener rules and NACLs. A broad pattern placed too early shadows everything beneath it.

The cache key

- By default the cache key is **only the URL path**. Headers, cookies and query strings are **excluded unless you add them**.
- Adding something to the cache key **multiplies the number of cached copies**. Including a cookie that varies per user destroys the cache entirely.
- So the rule is: include the minimum that genuinely changes the response, and nothing else.
- **Cache-Control headers from the origin** are respected, bounded by the behaviour's minimum and maximum TTL.

> ON THE EXAM
>
> A near-zero cache hit ratio is almost always a cache key that includes something highly variable. Check the key before blaming the TTL.

The three policy types

POLICY	CONTROLS
Cache policy	What is in the cache key, and the TTL settings. Also forwarded to the origin
Origin request policy	What is forwarded to the origin but NOT part of the cache key
Response headers policy	Headers CloudFront adds to responses: CORS, security headers, custom

ON THE EXAM

Origin request policy is the one people miss. It is how the origin sees a header for logging or geolocation without that header fragmenting the cache.

Invalidation, and why to avoid it

- **Invalidation** removes objects from every edge cache. The first 1,000 paths a month are free, and it takes minutes to propagate.
- **Versioned file names** are the better answer: publish app.v27.js rather than invalidating app.js.
- A new name is a **new object**, so it is never stale, needs no invalidation, and old versions expire naturally.
- Invalidation remains right for an **emergency**: wrong content published, or a security issue in a cached response.

> ON THE EXAM
>
> A deployment pipeline that invalidates /* on every release is a design smell. Versioned assets make the cache correct by construction.

Origin groups and origin protection

- An **origin group** holds a primary and a secondary origin, failing over on status codes you nominate, such as 500, 502, 503 and 504.
- That gives origin failover at the edge, without any DNS change and without waiting for a TTL to expire.
- **Origin Shield** adds a caching layer in one Region between the edges and your origin, raising the cache hit ratio.
- It matters most when many edge locations would otherwise each fetch the same object from your origin independently.

> ON THE EXAM
>
> Origin Shield collapses many edge misses into one origin request. For an expensive origin, that is a bigger saving than it first appears.

New: VPC origins

- Since **November 2024**, CloudFront can serve directly from an ALB, NLB or EC2 instance in a **private subnet**.
- The origin needs **no public IP address and no internet-facing load balancer**. It is unreachable except through your distribution.
- That replaces the old pattern of a public ALB protected by a **secret custom header**, which is one leaked header from being reachable.
- Extended since: **cross-account VPC origins via RAM** (November 2025), and **WebSocket support** (May 2026).

> ON THE EXAM
>
> The old pattern relied on a secret staying secret and on someone rotating it. A VPC origin removes the public endpoint entirely.

Protecting an S3 origin

- **Origin Access Control** lets CloudFront sign requests to S3, so the bucket policy can allow only that distribution.
- **Origin Access Identity is the legacy predecessor.** If an option offers OAI for new work, that is the dated answer.
- OAC supports **SSE-KMS**, all Regions, and **POST and PUT** requests, none of which OAI handled.
- Pair it with **Block Public Access** on the bucket, so the only path to the objects is through the distribution.

> ON THE EXAM
>
> OAC plus Block Public Access is the standard static site pattern: the bucket is private, and CloudFront is the only thing that can read it.

Restricting who can view

- **Signed URLs** grant time-limited access to **one file**. **Signed cookies** grant access to **many files** without changing any URL.
- So a single download link is a signed URL, while an entire subscriber video library is signed cookies.
- **Geo restriction** allows or blocks whole countries at the CloudFront level, using its own geolocation database.
- For anything more nuanced than a country list, use **AWS WAF**, which can combine geography with other conditions.

> ON THE EXAM
>
> Signed cookies exist because rewriting every URL in an application to sign it is impractical. The choice is about how many objects, not how secret they are.

CloudFront Functions or Lambda@Edge?

CLOUDFRONT FUNCTIONS

Tiny, fast, everywhere

- JavaScript, sub-millisecond, at every edge location
- Viewer request and viewer response only
- No network access and no request body access
- Header manipulation, redirects, URL rewrites, token checks

LAMBDA@EDGE

Fuller, slower, regional

- Node.js or Python, runs at Regional edge caches
- All four triggers, including origin request and response
- Network access, so it can call other services
- Up to 5 seconds at viewer, 30 at origin

THE TIEBREAKER

If it needs to call something, it is Lambda@Edge. If it only inspects and rewrites the request, it is a CloudFront Function, and far cheaper.

Cost, addresses and logs

- **Price classes** limit which edge locations are used. Fewer locations costs less and serves distant users more slowly.
- **Anycast static IPs** give a distribution a dedicated set of addresses, for partners who must allow-list them.
- **Standard logs** go to S3 and arrive with a delay. **Real-time logs** go to Kinesis Data Streams within seconds, with configurable fields and sampling.
- Real-time logs are charged per line, so **sample** rather than logging everything on a high-volume distribution.

> ON THE EXAM
>
> CloudFront addresses normally change, which is why partner allow-listing used to force a Global Accelerator or NLB. Anycast static IPs removed that constraint.

AWS WAF

- A **web ACL** holds rules evaluated in **priority order**. Actions are **Allow, Block, Count, CAPTCHA** or **Challenge**.
- **Count** is the safe way to introduce a rule: it records what would have matched without blocking anything.
- **Managed rule groups** from AWS and partners cover common threats, so you write very few rules yourself.
- Attaches to **CloudFront, ALB, API Gateway, AppSync, Cognito user pools** and more.

> ON THE EXAM
>
> Count mode is the same measure-before-enforcing pattern as Hooks warn mode, Allowed AMIs audit mode and DNS Firewall alert. Fifth appearance in this course.

Rate limiting and bots

- **Rate-based rules** block a source exceeding a request threshold in a window. The classic defence against credential stuffing and scraping.
- They can be scoped down, so the limit applies only to **/login** rather than the whole site, and aggregated by more than source IP.
- **Bot Control** distinguishes verified good bots, common bots and targeted automation, rather than blocking all automation.
- **CAPTCHA and Challenge** sit between allow and block: Challenge is silent to a real browser, while CAPTCHA asks the user to act.

> ON THE EXAM
>
> Challenge is the underused action. It stops most automation with no user-visible friction at all, which CAPTCHA cannot claim.

Shield Standard or Shield Advanced?

SHIELD STANDARD

Free and automatic

- Enabled for every AWS customer, nothing to configure
- Network and transport layer DDoS mitigation
- Covers CloudFront, Route 53 and load balancers
- No support engagement, no cost protection

SHIELD ADVANCED

Paid, with people

- Application-layer protection and richer detection
- Shield Response Team access during an event
- Cost protection: credits for attack-driven scaling
- Includes Firewall Manager. Monthly commitment

THE TIEBREAKER

Two clauses signal Advanced: access to AWS specialists during an attack, and refunds for the scaling an attack caused. Standard offers neither.

CloudFront or Global Accelerator?

CLOUDFRONT WHEN

HTTP, and cacheable

- Content can be cached at the edge
- HTTP and HTTPS only
- WAF, signed URLs, edge functions
- Caching removes origin load entirely

GLOBAL ACCELERATOR WHEN

Any protocol, no cache

- TCP or UDP, any port. Gaming, VoIP, IoT, MQTT
- Two static anycast IPs for allow-listing
- Fast regional failover, in around 30 seconds
- Traffic dials and endpoint weights for gradual shifts

THE TIEBREAKER

Global Accelerator is not a cache. It shortens the network path and fails over between Regions. If content is cacheable HTTP, CloudFront does more.

Global Accelerator in detail

- Two **static anycast IP addresses** that never change, fronting endpoints in multiple Regions.
- **Endpoint groups** are per Region, and a **traffic dial** sets what percentage of traffic each receives.
- Continuous health checks give **failover in roughly 30 seconds**, with no DNS involved and therefore no TTL to wait for.
- **Custom routing accelerators** map deterministically to a specific instance and port, for gaming sessions and virtual desktops.

> ON THE EXAM
>
> The absence of DNS is the point. Module 14's TTL and resolver-caching arithmetic simply does not apply, because the address never changes.

A CloudFront distribution in front of a dynamic application has a cache hit ratio of about 2 percent. The origin is under heavy load. The cache behaviour forwards all cookies and all query strings to the origin, and includes them in the cache key. Most responses are identical for all users.

The application needs the CloudFront-Viewer-Country header for analytics.

What should the team do?

A. Reduce the cache key to what actually varies the response, and use an origin request policy to forward the country header without caching on it

B. Increase the maximum TTL on the behaviour

C. Enable Origin Shield

D. Add more origins to an origin group

◆ PAUSE AND DECIDE

What should the team do?

A Shrink the cache key; forward via origin request policy

Cookies in the cache key give every user their own copy. An origin request policy forwards the header without fragmenting the cache.

B Raise the maximum TTL

Objects are not expiring; they are never being reused, because each request produces a distinct cache key. A longer TTL on a unique object achieves nothing.

C Origin Shield

Collapses duplicate origin fetches for the same object. With a near-unique key per request there are no duplicates to collapse.

D More origins

Spreads the same load across more servers. It treats the symptom while the cache continues to do nothing.

THE SIGNAL

A 2 percent hit ratio with identical responses is a cache key problem, always. Option B is the reflex answer and addresses expiry, not uniqueness.

> An application load balancer sits behind CloudFront. It is internet-facing, and a WAF rule on the ALB blocks any request that does not carry a secret custom header set by CloudFront. A security review objects that the ALB remains publicly reachable and that the header is a shared secret nobody has rotated in two years.
>
> The application must stay behind CloudFront.

What should the team implement?

A. Convert the ALB to internal and configure it as a CloudFront VPC origin

B. Rotate the custom header automatically with a Lambda function

C. Add an Origin Access Control to the ALB

D. Restrict the ALB's security group to CloudFront's published IP ranges

◆ PAUSE AND DECIDE

What should the team implement?

A Internal ALB as a VPC origin

Removes the public endpoint entirely. The ALB has no public address, so there is nothing to reach and no secret to protect.

B Rotate the header

Genuinely improves the existing design, and the ALB stays publicly reachable. It fixes the stale secret, not the exposure.

C OAC on the ALB

Origin Access Control signs requests to S3 origins. It does not apply to a load balancer.

D Security group to CloudFront ranges

The strongest alternative: it does restrict access. The ranges change and must be maintained, and any CloudFront distribution is inside them, including someone else's.

THE SIGNAL

Option D is the subtle one: CloudFront's IP ranges admit every CloudFront customer, not only your distribution. That is why the custom header existed in the first place.

> A multiplayer game server uses UDP on a custom port and runs in three Regions. Players report high latency and slow recovery when a Region becomes unhealthy. The team currently uses Route 53 latency-based routing with health checks.
>
> Some corporate players need to allow-list fixed IP addresses.

What should the team implement?

A AWS Global Accelerator with endpoint groups in each Region

B A CloudFront distribution in front of the game servers

C Route 53 geoproximity routing with a bias

D A Network Load Balancer with cross-Region targets

◆ PAUSE AND DECIDE

What should the team implement?

A Global Accelerator

UDP on any port, two static anycast IPs for allow-listing, traffic onto the AWS backbone at the nearest edge, and failover in about 30 seconds with no DNS.

B CloudFront

HTTP and HTTPS only, and game traffic is not cacheable. It cannot carry UDP at all.

C Geoproximity routing

Still DNS. It changes which endpoint is chosen, and failover still waits for health checks plus TTL plus resolver caching.

D NLB with cross-Region targets

An NLB is Regional. It does not provide global anycast entry or Regional failover.

THE SIGNAL

Three clauses each point the same way: UDP rules out CloudFront, static IPs rule out DNS-based answers, and slow recovery rules out anything using TTLs.

> A login endpoint is being attacked with credential stuffing from thousands of distributed addresses. Legitimate users must not be blocked, and the team's own monitoring bots must continue to work. Blocking whole countries is not acceptable.
>
> The site is behind CloudFront with AWS WAF attached.

Which combination should the team apply?

A. A rate-based rule scoped to /login, plus Bot Control, with new rules introduced in Count mode first

B. A single rate-based rule applied to the whole distribution

C. Geo restriction on CloudFront for the top attacking countries

D. Shield Advanced, which blocks credential stuffing automatically

◆ PAUSE AND DECIDE

Which combination should the team apply?

A Scoped rate limit, Bot Control, Count first

The scope-down keeps the limit off ordinary browsing, Bot Control distinguishes the team's own bots from attackers, and Count proves the effect before blocking.

B One rate rule for everything

A threshold low enough to stop login abuse will block normal browsing, since a page load makes many requests.

C Geo restriction

Explicitly ruled out, and attacks from distributed addresses are rarely confined to a few countries anyway.

D Shield Advanced

Focused on DDoS, with expert support and cost protection. Credential stuffing is a low-volume application attack, which is WAF's job.

THE SIGNAL

Three constraints, three features. Scope-down, bot classification, and Count mode each answer one of them exactly.

> A static website is served from an S3 bucket through CloudFront. The bucket is currently public so CloudFront can read it, and a security audit requires that it must not be. Objects are encrypted with SSE-KMS.
>
> An engineer proposes using an Origin Access Identity, which they have used before.

What should the team do?

A. Use Origin Access Control, and enable Block Public Access on the bucket

B. Use an Origin Access Identity as proposed

C. Keep the bucket public and restrict access with a bucket policy on CloudFront's IP ranges

D. Move the objects behind a VPC origin

◆ PAUSE AND DECIDE

What should the team do?

A OAC plus Block Public Access

OAC is the current mechanism and, unlike OAI, it supports SSE-KMS. Block Public Access then makes the distribution the only path.

B Origin Access Identity

Legacy, and it does not support SSE-KMS, which the scenario states is in use. It would fail on this bucket specifically.

C Public bucket, IP-range policy

Leaves the bucket public, which the audit forbids, and CloudFront's ranges admit every CloudFront customer.

D VPC origin

VPC origins serve from ALBs, NLBs and EC2 in private subnets. S3 is not a VPC resource, so this does not apply.

THE SIGNAL

The SSE-KMS detail is deliberate: it makes OAI not merely dated but actually non-functional here. That is why it is in the setup.

The five things to carry forward

- **A poor cache hit ratio is a cache key problem**, not a TTL problem. Include only what genuinely varies the response.
- **An origin request policy forwards without caching on it.** That is how the origin sees a header without fragmenting the cache.
- **VPC origins remove the public endpoint entirely**, replacing the secret custom header pattern.
- **OAC, not OAI.** OAC supports SSE-KMS, all Regions, and POST and PUT.
- **Global Accelerator is not a cache.** Any protocol, static IPs, and failover with no DNS involved.

> ON THE EXAM
>
> That completes the teaching modules. Next: what changed for SOA-C03, and what AWS has renamed since.